

LABORATORIO ANÁLISIS Y DETECCIONES EN SPLUNK

Rafael Guajardo
Técnico en Ciberseguridad

ÍNDICE

Alcance de laboratorio.....	3
Flujo de la investigación	3
Ejecución del ataque	4
Reconocimiento y enumeración:	4
Análisis en SPLUNK:	6
Detección de intentos fallidos	7
Análisis de eventos clave	10
Creación de Alertas en Splunk	11
Creación del Dashboard	12

Alcance de laboratorio

El laboratorio tiene como objetivo simular un ataque de fuerza bruta, en el cual el host REDQUEEN (Kali Linux) intenta acceder a recursos compartidos utilizando credenciales de un usuario víctima (fguajardo) en Windows 10, equipo que se encuentra unido al dominio YORHA.

La actividad generada durante el ataque será analizada mediante Splunk, con el fin de identificar y correlacionar los eventos de seguridad producidos.

Para este ejercicio se utilizarán las siguientes máquinas virtuales:

Sistema Operativo	Nombre	Cuenta	Dominio	IP
Windows Server 2022	Administrador	Administrador A. D	YORHA	192.168.1.89
Windows 10	fguajardo	Usuario	YORHA	192.168.1.88
Kali Linux	REDQUEEN	Usuario (atacante)	Sin Dominio	192.168.1.97

Flujo de la investigación

1. Detectar anomalía – intentos de login fallido
2. Confirmar compromiso – intento exitoso
3. Identificar atacante – IP 192.168.1.97
4. Delimitar ventana temporal - filtrado por una ventana de tiempo asociado a la IP
5. Descubrir actividad posterior – se reconocen eventos en la carpeta compartida
6. Correlacionar eventos – validas todos los eventos relacionados
7. Reconstruir timeline y Concluir:

Fuerza bruta exitosa + acceso a recurso compartido + actividad sobre archivos

Ejecución del ataque

Reconocimiento y enumeración:

En el sistema operativo Kali, se realiza un escaneo de red para identificar los hosts activos mediante la siguiente línea de comando:

```
nmap -sn 192.168.1.0/24
```

A partir de los resultados, se selecciona como objetivo la máquina con IP 192.168.1.88. Posteriormente, se ejecuta un reconocimiento para identificar puertos y servicios: *nmap -Pn -sV -O 192.168.1.88*

```
(hackqueen@redqueen) ~  
$ nmap -Pn -sV -O 192.168.1.88  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-25 16:47 -0400  
Nmap scan report for 192.168.1.88  
Host is up (0.00025s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE        VERSION  
135/tcp   open  msrpc          Microsoft Windows RPC  
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn  
445/tcp   open  microsoft-ds?  
MAC Address: 08:00:27:37:D0:F7 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Microsoft Windows 10  
OS CPE: cpe:/o:microsoft:windows_10  
OS details: Microsoft Windows 10 1709 - 22H2  
Network Distance: 1 hop  
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.47 seconds  
  
(hackqueen@redqueen) ~  
$
```

El resultado del escaneo indica que el host objetivo ejecuta Windows 10 y presenta los siguientes puertos abiertos asociados a servicios de red:

- Puerto 135: MSRPC (puerto 135)
- Puerto 139: NetBIOS-SSN (puerto 139)
- Puerto 445: Microsoft-DS

El siguiente paso consiste en enumerar los recursos compartidos mediante **SMB**: `smbclient -L //192.168.1.88 -U 'YORHA\fguajardo'`

```
(hackqueen@redqueen)-[~]
$ smbclient -L//192.168.1.88 -U 'YORHA\fguajardo'
Password for [YORHA\fguajardo]:

      Sharename      Type      Comment
      -----      -
      ADMIN$         Disk      Admin remota
      C$              Disk      Recurso predeterminado
      IPC$            IPC       IPC remota
      nuevo           Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.1.88 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(hackqueen@redqueen)-[~]
$
```

Luego se creará un archivo de texto para subirlo al directorio compartido: `echo "lab splunk smb">prueba.txt` y luego la máquina Kali ingresará al usuario con el comando:

`smbclient //192.168.1.88/nuevo -U 'YORHA\fguajardo'`

El servicio solicita las credenciales del usuario del dominio. En este escenario, se ejecutan múltiples intentos de autenticación de forma intencional, con el objetivo de simular un ataque de fuerza bruta.

```
session setup failed: NT_STATUS_LOGON_FAILURE

(hackqueen@redqueen)-[~]
$ smbclient //192.168.1.88/nuevo -U 'YORHA\fguajardo'
Password for [YORHA\fguajardo]:
session setup failed: NT_STATUS_LOGON_FAILURE

(hackqueen@redqueen)-[~]
$ smbclient //192.168.1.88/nuevo -U 'YORHA\fguajardo'
Password for [YORHA\fguajardo]:
session setup failed: NT_STATUS_LOGON_FAILURE

(hackqueen@redqueen)-[~]
$ smbclient //192.168.1.88/nuevo -U 'YORHA\fguajardo'
Password for [YORHA\fguajardo]:
session setup failed: NT_STATUS_LOGON_FAILURE

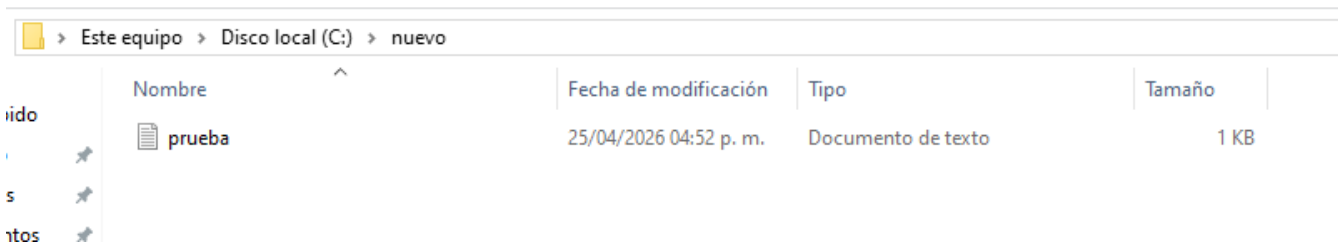
(hackqueen@redqueen)-[~]
$ smbclient //192.168.1.88/nuevo -U 'YORHA\fguajardo'
Password for [YORHA\fguajardo]:
session setup failed: NT_STATUS_LOGON_FAILURE
```

Luego, desde Kali Linux, utilizando la contraseña válida, se accede al recurso compartido y se ejecuta el comando `put prueba.txt` para cargar el archivo de texto en el directorio.

```
smb: \> put prueba.txt
putting file prueba.txt as \prueba.txt (1,1 kB/s) (average 1,1 kB/s)
smb: \> ls
.                D          0  Sat Apr 25 16:52:45 2026
..               D          0  Sat Apr 25 16:52:45 2026
prueba.txt       A        15  Sat Apr 25 16:52:45 2026

38166669 blocks of size 4096. 29180158 blocks available
smb: \> █
```

Como podrán verificar, en el sistema operativo de Windows 10 (víctima) se podrá ver la creación del archivo ‘*prueba*’ que el atacante realizó desde Kali.



	Nombre	Fecha de modificación	Tipo	Tamaño
ido				
.				
s				
ntos				
	prueba	25/04/2026 04:52 p. m.	Documento de texto	1 KB

Análisis en SPLUNK:

Durante un análisis previo, es necesario considerar varios factores para determinar si se trata de un falso positivo o de un ataque de fuerza bruta orientado al acceso de archivos compartidos y la creación de documentos. Este tipo de ataque suele apoyarse en herramientas automatizadas que utilizan diccionarios para intentar adivinar credenciales. Por ello, es esperable observar múltiples intentos fallidos en un corto período de tiempo antes de un acceso exitoso.

Además, es importante revisar el horario en que ocurre la actividad, en relación con la jornada laboral de la organización, para identificar comportamientos anómalos. También se debe analizar si la dirección IP de origen es interna o externa, y si el usuario o equipo involucrado pertenece al dominio corporativo.

La correlación de estos elementos permite evaluar con mayor precisión si se trata de un intento de fuerza bruta o de un escenario legítimo, como un usuario que ingresó incorrectamente su contraseña en reiteradas ocasiones.

El siguiente paso será ingresar a Splunk y en la barra de búsqueda filtramos la detección de eventos que se registran en el visor de eventos y que se encuentran centralizados en el SIEM.

Detección de intentos fallidos

La siguiente métrica me permite filtrar todos los eventos fallidos y aprobados que se encuentran en el índice 'wineventlog' y el resultado de este los agrupo en bloques de 5 minutos, ordenándolos desde el registro más actual, al más antiguo.

```
index=wineventlog EventCode=4625 OR EventCode=4624
| bin _time span=5m
| sort -_time
```

Esto permite que la búsqueda tenga mejor precisión ya que en un entorno real si dentro de este periodo de 5 minutos existen muchos intentos fallidos, es una sospecha relevante de que fue un ataque de fuerza bruta.

i	Time	Event
>	25/04/2026 16:50:00.000	04/25/2026 04:52:02.568 PM LogName=Security EventCode=4624 EventType=0 ComputerName=fcliente1.yorha.center Show all 70 lines host = fcliente1 source = WinEventLog:Security sourcetype = WinEventLog
>	25/04/2026 16:50:00.000	04/25/2026 04:51:58.018 PM LogName=Security EventCode=4625 EventType=0 ComputerName=fcliente1.yorha.center Show all 61 lines host = fcliente1 source = WinEventLog:Security sourcetype = WinEventLog

Podemos ordenar la evidencia a través de una tabla ingresando el siguiente query SPL:

```
index=wineventlog (EventCode=4625 OR EventCode=4624)
| rex field=Message "Dirección de red de origen:\s+(?<ip_origen>\d+\.\d+\.\d+\.\d+)"
| rex field=Message "Nombre de estación de trabajo:\s+(?<equipo_origen>[^\r\n]+)"
| table _time host Account_Name ip_origen equipo_origen EventCode
| sort -_time
```

_time	host	Account_Name	ip_origen	equipo_origen	EventCode
2026-04-25 16:52:02.568	fcliente1		192.168.1.97	REDQUEEN	4624
2026-04-25 16:51:58.018	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:57.278	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:56.488	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:55.629	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:54.829	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:54.015	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:53.138	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:52.248	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:51.151	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:49.809	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:47.919	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:47.219	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:46.549	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:45.880	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:45.200	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:44.520	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:43.849	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:43.180	fcliente1		192.168.1.97	REDQUEEN	4625
2026-04-25 16:51:42.508	fcliente1		192.168.1.97	REDQUEEN	4625

Esto permite visualizar el comportamiento de autenticación del usuario en la ventana temporal analizada. El registro es evidente, hubo alrededor de 19 intentos fallidos (4625) durante 1 registro exitoso (4624) en el periodo de tiempo de un 1 minuto. Esto confirma un acceso a la cuenta por un activo con el nombre del equipo REDQUEEN y que por motivos internos no está dentro del registro del dominio.

Con esta información, ya se sabe que el usuario REDQUEEN con IP 192.168.1.97 realizó un ataque de fuerza bruta y pudo acceder al host fcliente1 el día 25 de abril de 2026 a las 16:52:02. Es de suma importancia la fecha y hora ya que por el momento se sabe que pudo acceder a la máquina. Sin embargo, ahora se necesita saber si realizó algún otro evento (como ejecutar algún proceso, crear algún archivo, etc). No podemos especular por lo que se debe filtrar en base a los datos que ya tenemos (fecha, hora, hostname y IP de origen).

El siguiente paso en Splunk es realizar el siguiente Query SPL:

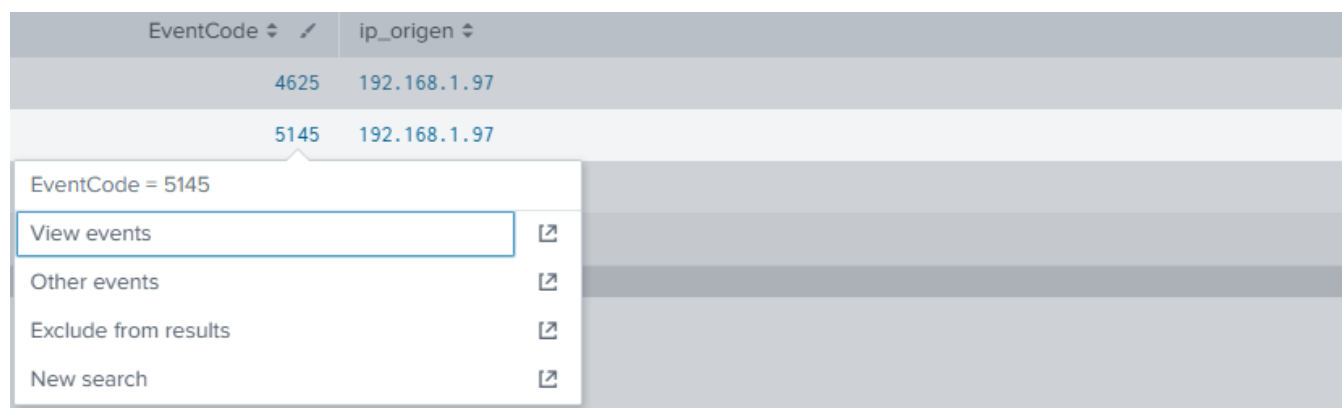
```
index=wineventlog host=fcliente1 earliest="04/25/2026:16:51:00" latest="04/25/2026:16:54:00"
| rex field=Message "(Dirección de (red )?de origen|Dirección de origen|Dirección de
cliente):\s+(?<ip_origen>\d+\.\d+\.\d+\.\d+)"
| search ip_origen=192.168.1.97
| stats count by EventCode ip_origen
| sort -count
```

EventCode	ip_origen	count
4625	192.168.1.97	32
5145	192.168.1.97	4
5140	192.168.1.97	2
4624	192.168.1.97	1

Aquí se le indica a Splunk que busque eventos dentro del índice *wineventlog*, específicamente del host fcliente1 (víctima), en una ventana de tiempo comprendida entre las 16:51 y las 16:54 del día 25/04/2026. Luego, mediante *rex*, se extrae desde el campo *Message* la dirección IP de origen y se almacena en el campo *ip_origen*. Posteriormente, se filtran únicamente los eventos asociados a la IP 192.168.1.97. Finalmente, con *stats count by EventCode ip_origen*, se contabiliza la cantidad de eventos generados por esa IP, agrupándolos por código de evento.

Es decir, Splunk está mostrando qué eventos realizó la IP 192.168.1.97 contra el equipo fcliente1 durante ese intervalo de tiempo.

Para analizar los registros, haz clic en el número de evento: EVENTCODE y selecciona la opción: *View events*



Al seleccionar el evento en detalle 5140, concluimos que: *“Se tuvo acceso a un objeto del recurso compartido de red”*. Esto significa que el usuario accedió al recurso compartido (pudo acceder a la carpeta con el nombre *‘nuevo’*)

```
25/04/2026 16:52:02.575 04/25/2026 04:52:02.575 PM
LogName=Security
EventCode=5140
EventType=0
ComputerName=fcliente1.yorha.center
SourceName=Microsoft Windows security auditing.
Type=Información
RecordNumber=27491
Keywords=Auditoria correcta
TaskCategory=File Share
OpCode=Información
Message=Se tuvo acceso a un objeto de recurso compartido de red.

Sujeto:
  Id. de seguridad: S-1-5-21-3279314550-455425279-1810561719-1103
  Nombre de cuenta: fgaujardo
  Dominio de cuenta: YORHA
  Id. de inicio de sesión: 0x49DB21

Información de evento:
  Tipo de objeto: File
  Dirección de origen: 192.168.1.97
  Puerto de origen: 46262

Información de recurso compartido:
  Nombre de recurso compartido: \\*\nuevo
  Ruta de acceso de recurso compartido: \\??\C:\nuevo

Información de solicitud de acceso:
  Máscara de acceso: 0x1
  Accesos: ReadData (o ListDirectory)

Collapse
```

Posteriormente se revisa en detalle el siguiente evento y se concluye lo siguiente: *“se comprobó un objeto de recurso compartido de red para averiguar si se puede conceder el acceso deseado al cliente”*

Esto significa que Windows está evaluando si el usuario tiene permisos para hacer algo (crear, modificar o ejecutar un proceso) en la carpeta compartida.

```
25/04/2026 04:25/2026 04:52:48.484 PM
16:52:48.484 LogName=Security
EventCode=5145
EventType=0
ComputerName=fcliente1.yorha.center
SourceName=Microsoft Windows security auditing.
Type=Información
RecordNumber=27495
Keywords=Auditoria correcta
TaskCategory=Detailed File Share
OpCode=Información
Message=Se comprobó un objeto de recurso compartido de red para averiguar si se puede conceder el acceso deseado al cliente.

Sujeto:
  Id. de seguridad:      S-1-5-21-3279314550-455425279-1810561719-1103
  Nombre de cuenta:     fguajardo
  Dominio de cuenta:    YORHA
  Id. de inicio de sesión: 0x490B21
```

El punto clave es que Windows registra una sesión autenticada asociada a la IP de origen 192.168.1.97, desde la cual se accede, a través del host fcliente1, al recurso compartido (la carpeta “nuevo”).

```
Información de red:
  Tipo de objeto:      File
  Dirección de origen:  192.168.1.97
  Puerto de origen:    46262

Información de recurso compartido:
  Nombre de recurso compartido: \\*\nuevo
  Ruta de acceso de recurso compartido: \\?\C:\nuevo
  Nombre de destino relativo: \

Información de solicitud de acceso:
  Máscara de acceso:    0x80
  Accesos:              ReadAttributes

Resultados de la comprobación de acceso:
  ReadAttributes: Concedido por D:(A;;FA;;;WD)
```

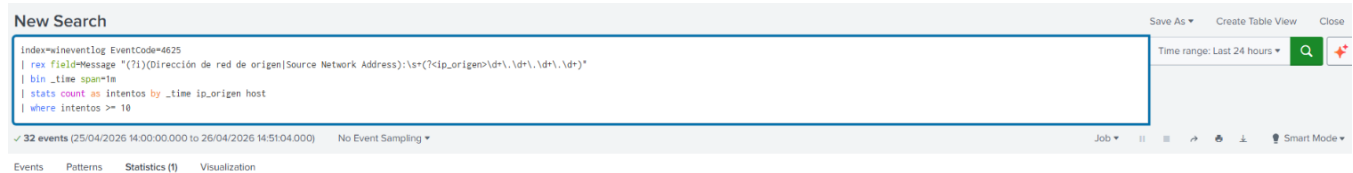
Análisis de eventos clave

EventCode 4625	Intentos fallidos
EventCode 4624	Intentos exitosos
EventCode 5140	Acceso a recursos compartidos
EventCode 5145	Validación de permisos

Creación de Alertas en Splunk

El siguiente paso será crear una alerta que detecte intentos de autenticación. En la barra de búsqueda ingresar el query que haga la detección y luego haz clic en el botón Save as que se encuentra en la parte derecha de la barra de search :

```
index=wineventlog EventCode=4625 | rex field=Message "(?i)(Dirección de red de origen|Source Network Address):\s+(?<ip_origen>\d+\.\d+\.\d+\.\d+)" | bin_time span=1m | stats count as intentos by _time ip_origen host | where intentos >= 10
```



Completa el cuadro de configuración de alerta ingresando los siguientes parámetros:

Title: 4625 – Ataque Fuerza Bruta

Descripción:

Alert Type: Scheduled / run on Cron Schedule / Cron Expression `*/5 * * * *`

Expires: 5 minutes

Trigger Alert when: number of Results / is greater than 0

Trigger: Once

Throttle: activado

Supress triggering for 300 seconds (también puede ser 5 minutos)

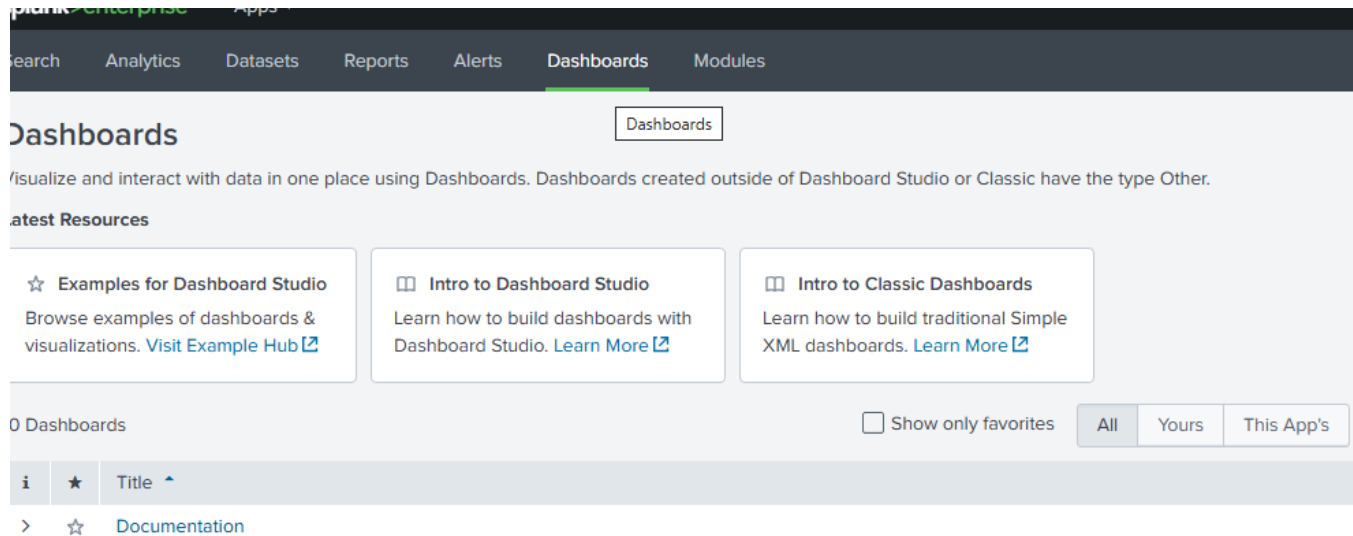
Trigger Action: add to triggered Alerts

severity: High

A screenshot of the 'Save As Alert' configuration window in Splunk. The window is divided into two main sections: 'Settings' on the left and 'Trigger Conditions' and 'Trigger Actions' on the right. In the 'Settings' section, the 'Title' is '4625 - ataque fuerza bruta', 'Description' is 'Optional', 'Permissions' are set to 'Private', 'Alert type' is 'Scheduled', 'Time Range' is 'Last 24 hours', 'Cron Expression' is '*/5 * * * *', and 'Expires' is '5 minute(s)'. In the 'Trigger Conditions' section, 'Trigger alert when' is set to 'Number of Results' which is 'is greater than' '0'. The 'Trigger' is set to 'Once'. 'Throttle' is checked. 'Suppress triggering for' is set to '300 second(s)'. In the 'Trigger Actions' section, there is one action: 'Add to Triggered Alerts' with a severity of 'Medium'. At the bottom right, there are 'Cancel' and 'Save' buttons.

Creación del Dashboard

En el panel principal de Splunk, haz clic en la opción “Dashboard” ubicada en la parte superior de la pantalla. Luego, selecciona el botón “Create New Dashboard”, situado en la esquina superior derecha.



En el cuadro de configuración, ingresa el nombre del panel y una breve descripción. Luego, selecciona el tipo de panel que deseas crear; para comenzar, se recomienda utilizar la opción **Clásica**.

Create New Dashboard

×

Dashboard Title

Required

Edit ID

Description

Optional

Permissions

Private

Dashboard type

ⓘ

Classic Dashboards

The traditional Splunk dashboard builder

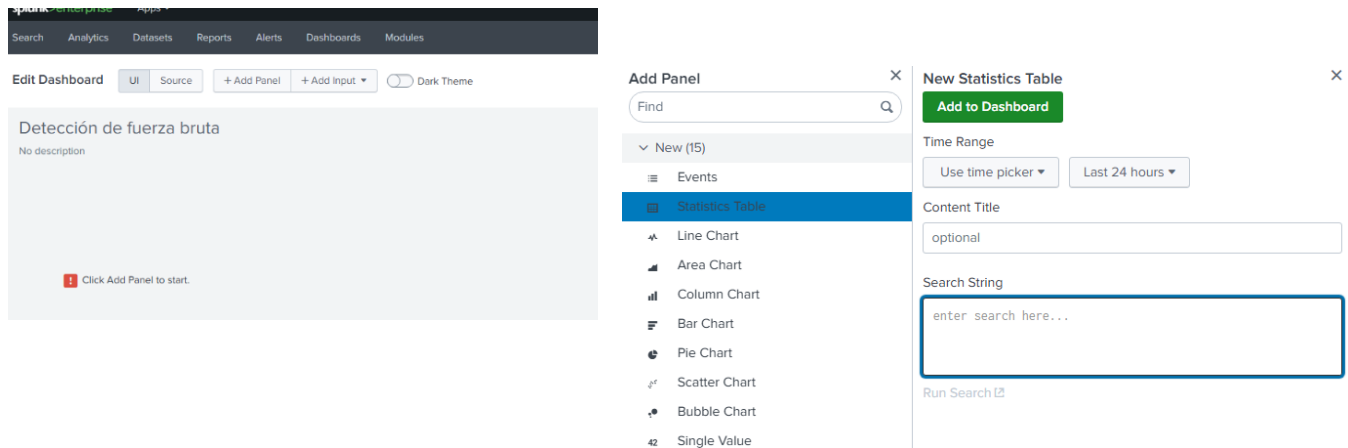
Dashboard Studio

A new builder to create visually-rich, customizable dashboards

Cancel

Create

En la siguiente pantalla, haz clic en la opción “Add Panel”. Esto desplegará automáticamente un conjunto de herramientas que permite agregar métricas al dashboard. Para este caso, selecciona “Statistic Table” y “Line Chart”, con el objetivo de visualizar un gráfico junto a su respectiva tabla de eventos resumidos.

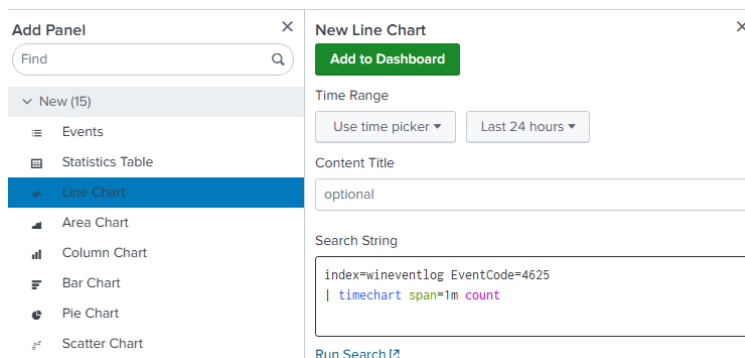


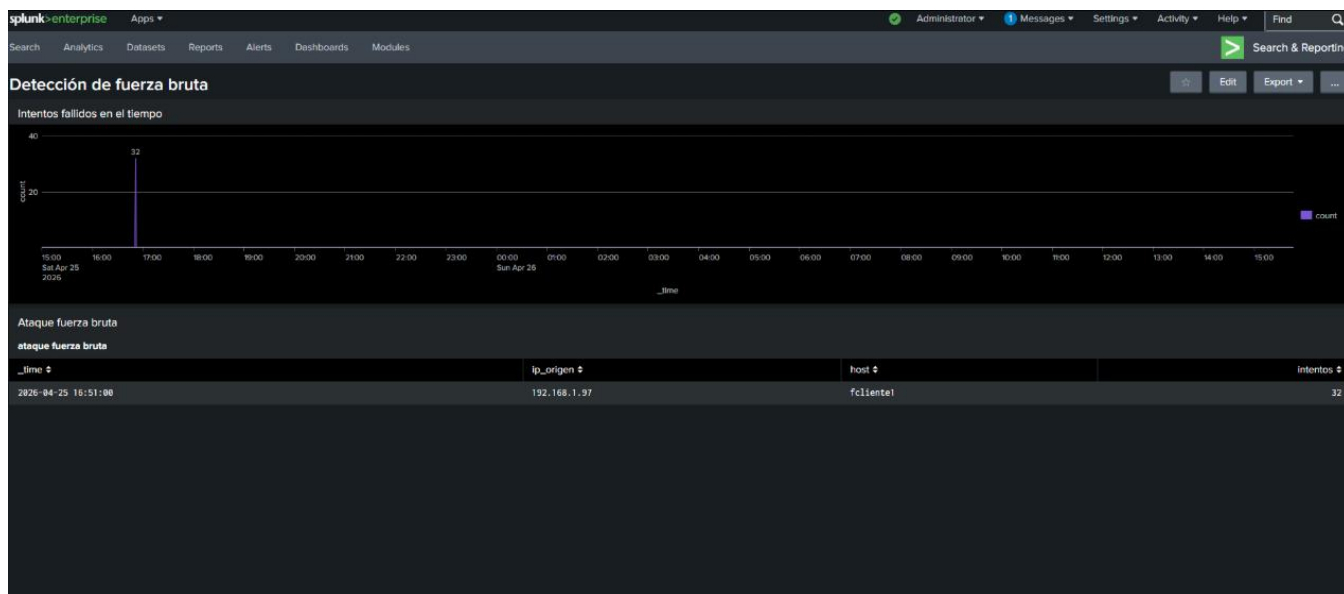
En la tabla de estadísticas debes ingresar el título y el Query que filtra los intentos de login fallidos:

```
index=wineventlog EventCode=4625
| rex field=Message "(?i)(Dirección de red de origen|Source Network
Address):\s+(?<ip_origen>\d+\.\d+\.\d+\.\d+)"
| bin_time span=1m
| stats count as intentos by _time ip_origen host
| where intentos >= 10
| sort -_time
```

y en Line Chart ingresas el siguiente Query:

```
index=wineventlog EventCode=4625
| timechart span=1m count
```





Este dashboard muestra una detección básica de ataque de fuerza bruta sobre logs de Windows (EventCode 4625).

- Representa la cantidad de intentos fallidos de login en el tiempo.
- Hay un pico claro (32 intentos) en un intervalo específico (~16:51).
- Eso indica un comportamiento anómalo: múltiples intentos concentrados → típico de fuerza bruta.